

密 级： 公开

加密论文编号：

论文题目： 面向云原生应用权限提升漏洞的动态防
控技术研究

学 号： M202310652

研 究 生： 韩晓阳

专 业 名 称： 计算机科学与技术

2026 年 5 月 1 日

面向云原生应用权限提升漏洞的动态防控技术研究

**Research on Dynamic Prevention and Control
Technologies for Privilege Escalation
Vulnerabilities in Cloud-Native Applications**

研究生：韩晓阳

指导教师：孙昌爱

北京科技大学 计算机与通信工程学院

北京 100083，中国

Doctor Degree Candidate: Xiaoyang Han

Supervisor: Chang'ai Sun

School of Computer and Communication Engineering

University of Science and Technology Beijing

30 Xueyuan Road, Haidian District

Beijing 100083, P.R.CHINA

中图分类号:

学校代码:

10008

U D C:

密 级:

公开

北京科技大学硕士学位论文

论文题目: 面向云原生应用权限提升漏洞的动态防控技术研究

研究生: 韩晓阳

指 导 教 师: 孙昌爱 单位: 北京科技大学 职称: 教授

指 导 小 组 成 员: 单位: 职称:

 单位: 职称:

论文提交日期: 2026 年 5 月 1 日

学位授予单位: 北 京 科 技 大 学

1 面向云原生应用权限提升漏洞的自动化防控技术报告

1.1 背景与问题

Kubernetes 系统凭借其自动化管理与弹性伸缩能力，已成为容器编排领域的事实标准。在持续集成/持续部署、服务治理、可观测性与功能拓展需求驱动下，生产环境常引入 Prometheus、Jenkins、Istio 等第三方开源应用。此类组件的接入通常需要授予其访问 Kubernetes 资源（如 Pods、Secrets、Services）的权限以保障功能正常运行，但也带来权限配置不当与权限边界失控的风险。

攻击者可能利用第三方应用及其依赖库中的高危漏洞劫持容器并获得基础权限，进而借助过度开放的 ServiceAccount、缺乏最小权限约束的 ClusterRole 等配置不当问题发起权限提升攻击，最终威胁集群整体安全。例如 CVE-2024-56513、CVE-2022-29179 等事件表明，漏洞利用与权限配置错误往往呈链式叠加效应，使“快速缓解”在补丁完全可用之前成为必要环节。

另一方面，漏洞的安全响应存在显著滞后：部分高危漏洞的完全修复周期可长达数年。统计结果显示，仅约 61.8% 的 Kubernetes 开源应用权限提升高危漏洞在公开前完成修复，且仅约 18% 的漏洞能够在公开前至少 7 天得到修复，为用户留出更新迁移与风险缓解的缓冲时间；同时在漏洞上报、漏洞公开与漏洞修复之间也存在不同程度的延迟。

在此情境下，大模型为 CVE 的快速缓解与防控提供了关键的智能化支撑：其一，利用语义理解能力从公告、代码与讨论材料中提取与权限边界相关的关键信息，缩短人工阅读与归纳的时间；其二，在证据约束与结构化输出要求下，生成可解释、可执行的候选缓解策略，从而加速“分析—生成—筛选—交付”的闭环。

1.1.1 权限提升漏洞的分类

权限提升漏洞是指攻击者利用应用或系统中的安全缺陷，获得超过其当前权限级别的访问能力，从而实施越权操作或扩大攻击影响。针对 Kubernetes 容器化应用的权限提升攻击方式与威胁模型呈现多元化。为便于将漏洞特征映射到可实施的控制域（例如身份与权限、网络隔离、运行时检测与审计），本文采用基于根本成因的分类视角，对常见路径进行归纳总结，如图1-1 所

示。

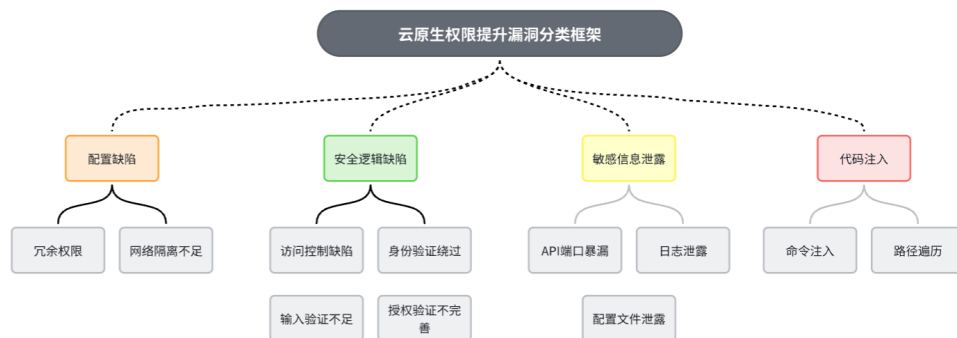


图 1-1: Kubernetes 容器化应用权限提升攻击方式分类

1. 配置缺陷：应用或基础设施的配置不当导致的安全漏洞，包括：

- 权限配置过宽：Kubernetes RBAC 配置不当、IAM 策略权限过大等，允许低权限用户获得高权限访问；
- 网络隔离不足：容器、Pod 或服务间缺乏网络隔离，导致攻击者可以横向移动获取其他权限上下文。

2. 安全逻辑缺陷：应用代码中的安全机制设计或实现不当，包括：

- 访问控制缺陷：应用的权限检查不完全或存在逻辑漏洞，允许绕过权限验证；
- 身份验证绕过：认证机制设计缺陷，攻击者可以冒充他人身份或跳过认证步骤；
- 授权验证不完善：权限检查在某些操作路径或边界条件下缺失。

3. 敏感信息泄露：重要的身份、密钥或权限信息意外暴露，包括：

- API 端口暴露：管理接口、内部 API 或调试端口未受保护暴露在网络上；
- 日志泄露：日志文件包含敏感信息（如 token、密钥、命令历史）；
- 配置文件泄露：配置文件包含硬编码的凭证或密钥。

4. 代码注入：应用对用户输入的处理不当，允许注入恶意代码，包括：

- 命令注入：应用直接执行用户提供或可控的命令，攻击者可以执行任意系统命令；
- 路径遍历：应用文件访问检查不完整，攻击者可以访问系统其他部分的文件。

1.1.2 动机与挑战

在云原生场景下，补丁发布与升级窗口的滞后、运行环境的异构性，以及第三方应用带来的复杂权限边界，使得权限提升漏洞的处置往往需要先给出**可快速落地的临时防控**。因此，本文将动机聚焦于把防控措施落到可动态下发的安全控制域上：利用 Falco 等运行时检测、OPA/Gatekeeper 等准入策略、NetworkPolicy 等网络隔离与平台安全基线，对攻击链关键环节施加约束，从而在补丁未就绪或难以及时升级的阶段降低风险暴露面。

面向权限提升漏洞的临时防控，自动化方案需要同时满足三个要求：**可解释**（能够说明为何该措施对应风险点）、**可执行**（包含可落地步骤与验证/回滚边界）、**可复核**（关键结论可回溯到证据与环境假设）。然而，漏洞描述与环境信息存在噪声与缺失，且不同控制手段对业务的副作用差异显著，使得“生成—筛选—交付”难以通过单一启发式规则完成。为此，本文采用结构化产物、证据来源追踪与规则化质量评价相结合的方式，将策略生成过程约束到可检查的中间结果上，以降低不确定性对交付质量的影响。

在上述约束下，引入大模型的主要动机在于提升“信息理解+候选生成”的效率与覆盖度：面对大量非结构化证据与多样化的攻击链路，大模型能够在检索增强上下文的支持下，归纳漏洞成因、定位权限边界与可控点，并快速给出多方案候选。同时，本文通过结构化字段、动作序列规范与门槛评价，将大模型的生成结果转化为可检查、可复核的交付产物，使其智能化能力服务于 CVE 的快速缓解与防控，而不是替代必要的验证与审计流程。

进一步而言，云原生场景中“补丁发布/升级窗口滞后”与“运行环境异构”的客观约束，使得临时缓解往往更依赖 extbf 可动态下发与可快速回滚的安全控制手段。相较于直接修改业务代码，动态安全工具与平台原语能够以更小的变更半径对攻击链关键环节施加约束：例如通过准入控制阻断高风险配置进入集群、通过网络隔离限制横向移动路径、通过运行时检测捕获可疑系统调用与容器逃逸征兆等。这类手段天然适合被表达为本文定义的 $\pi = \langle \text{layer}, \text{method}, \text{actions} \rangle$ 中的可执行操作序列，并可通过验证步骤与回滚边界实现工程化交付。

为便于将“临时防控”的动机具体化，本文将常见动态控制与工具能力归纳为如下可落地控制点：

- **准入与策略约束**：基于 OPA/Gatekeeper 或 Kyverno 等准入策略，对特

权容器、宿主机路径挂载、危险 capabilities、过宽 RBAC 绑定等高风险资源进行阻断或强制修正；

- **网络隔离与最小连通**：基于 NetworkPolicy 对命名空间/工作负载间通信进行白名单化，抑制利用漏洞后的横向移动与数据外传路径；
- **运行时检测与响应**：基于 Falco 等运行时安全工具，监测异常系统调用、提权相关行为与逃逸迹象，并联动告警、隔离或自动化处置动作；
- **安全基线与最小权限**：基于 Pod 安全基线（如 Pod Security Standards）与账户/令牌治理，降低默认配置下的权限暴露面。

本文面向云原生权限提升漏洞的临时防控需求，构建一套以“证据约束 + 结构化产物 + 质量评价”为核心的自动化策略生成流程。整体框架由三个阶段组成：

（1）知识库与上下文构建：从 CVE 公告、源代码、Issue、PR 等多源材料中提取证据片段，结合检索增强形成带来源标注的安全上下文，为后续分析提供可追溯的信息基础。

（2）智能化策略生成与优化：以大模型作为推导引擎，并在证据约束、流程分解与格式校验下的思维链条下生成候选策略；通过评审反馈对缺失步骤、适用边界与风险副作用等要素进行定向补全与修订。

（3）多维质量评价与排名：以门槛评分与三维质量向量（有效性、无干扰性、可部署性）对候选策略进行规则化检查与对比排序，为交付选择提供统一尺度。

1.2 形式化定义

1.2.1 基本对象

本节给出框架的形式化定义体系，用于精确刻画漏洞输入、策略生成与质量评价之间的关系。

定义 1（漏洞实例）：令 $\mathcal{V}$ 表示漏洞实例集合，每个漏洞 $v \in \mathcal{V}$ 由三元组表示：

$$v = \langle \text{id}, d, m \rangle$$

其中 id 为 CVE 标识符， d 为 CVE 公告或其他文本描述， m 为元数据（如严重性、受影响组件等）。

定义 2（安全上下文）：令 $\mathcal{C}$ 表示上下文集合，上下文 $c \in \mathcal{C}$ 是与漏洞 v

相关的证据性文本或结构化信息的集合。

在本框架中，上下文构建强调“证据来源可标注”，可将上下文表达为：

$$c = \{(t_i, \text{src}_i)\}_{i=1}^n$$

其中 t_i 为片段内容， src_i 为来源标识（例如文档路径、公告链接等）。

定义 3（安全策略）：令 Π 表示安全策略空间，每个策略 $\pi \in \Pi$ 是一个结构化对象，包含三个核心字段：

$$\pi = \langle \text{layer}, \text{method}, \text{actions} \rangle$$

其中 **layer** 描述防控所在的技术层面（例如身份与权限、网络隔离、运行时检测等），**method** 是防控方法的分类或摘要（例如网络隔离与认证强化），**actions** 是具体可执行的防控操作序列，详见定义 3.1。

定义 3.1（防控操作序列）：定义 **actions** 为一个有序的防控操作集合：

$$\text{actions} = [a_1, a_2, \dots, a_n]$$

其中每个操作 a_i 描述一个具体的防控步骤，可能涉及安全工具的使用或系统/集群配置的修改。为便于落地与复核，操作描述通常应包含：(1) 可执行的步骤或命令；(2) 作用对象或组件（例如 NetworkPolicy、RBAC 配置等）；(3) 预期效果与验证方式；(4) 可能的副作用与回滚方案。

1.2.2 评价与选择

本节给出“评分”与“排名”的形式化定义，以支持跨方法与跨模型的可比性分析。

定义 4（单策略评分函数）：定义评分函数 $s : \Pi \rightarrow [0, 1]$ ，用于刻画策略是否满足最低可用性阈值。在临时防控语境下，评分函数的设计应关注可执行性与快速部署可行性而非永久修复，综合考虑策略的可部署性、有效性和副作用。

定义 5（三维度质量向量）：定义质量向量 $q(\pi)$ 为三维向量：

$$q(\pi) = (E(\pi), I(\pi), D(\pi))$$

其中 E 为有效性（Effectiveness：覆盖攻击面/阻断关键路径）， I 为无干扰性（Interference：对业务的副作用与误报风险越低越好）， D 为可部署性（Deployability：语法与步骤清晰、可操作）。

定义 6（多策略排名）：对候选集合 $\Pi_v \subseteq \Pi$ ，定义排名算子 R 输出一个

排列：

$$R(\Pi_v, \text{dim}) \rightarrow (\pi_{(1)}, \pi_{(2)}, \dots, \pi_{(k)})$$

其中 $\text{dim} \in \{E, I, D\}$ 表示评价维度, $\pi_{(1)}$ 为该维度最优候选。“最佳策略”存在多目标权衡时排名比单一分数更适合呈现策略选择在不同维度下的权衡关系。

1.3 总体框架

该框架采用三阶段流程：

阶段 1：开源应用知识库构建。以 CVE 描述与开源应用知识库为输入，通过检索增强与证据汇聚形成带来源标注的安全上下文 $c \in \mathcal{C}$ ，为后续推导提供可验证的信息基础。

阶段 2：智能化策略生成与优化。以漏洞实例 v 为输入，首先构造安全上下文 c ，采用分阶段推导生成防控方案，并通过评审反馈对候选策略进行迭代改进。输出为结构化策略对象集合 Π_v 。

阶段 3：评价与质量控制。对候选策略进行结构化评价，输出门槛评分 $s(\pi)$ 、质量向量 $q(\pi)$ 和排名序列 $R(\Pi_v, \text{dim})$ ，用于筛选和排序可交付的策略。

1.4 知识库构建

知识库构建阶段的目标是将非结构化的漏洞描述转化为带来源标注的证据集合 $c = \{(t_i, \text{src}_i)\}_{i=1}^n$ ，通过爬虫拉取源代码、文档、Issue、PR 等多源信息，采用分层检索、结构化分块、向量化三层策略实现。

数据来源与收集。本地部分遍历代码仓库收集可读文本文件（代码、配置、文档），过滤二进制内容；远程部分通过 GitHub API 获取 Issue、PR、Security Advisory，包含用户报告、补丁讨论和官方安全建议的信息，作为原始数据。

分块策略。代码文件最大 160 行单块，遇到函数、类或注释时提前截断，块间保留 20 行重叠；文本与 Markdown 文件采用 1600 字符窗口、200 字符重叠、段落边界合并，兼顾检索粒度与上下文完整性。

去重与规模控制。计算块内容哈希值删除重复，过滤超长输入（单文件 >2MB）防止内存溢出，通过 `-max-files` 参数（默认 1500）限制文件总数以平衡覆盖度与效率。

向量化与索引构建。采用 HuggingFaceEmbeddings（默认 sentence-transformers/all-mpnet-base-v2）进行语义编码，FAISS 索引加速检索，向量库（`index.faiss`）、

元数据（meta.jsonl）、配置（config.json）持久化至本地磁盘。

来源追踪与元数据保留。每个块保留元数据标签（来源文件路径、块 ID、块类型、大小、行数），检索结果附带元数据供后续验证和差异化处理。

1.5 策略生成

1.5.1 方法概览

策略生成阶段旨在根据漏洞实例 v 与安全上下文 c 形成候选策略集合 Π_v 。流程由证据汇聚、结构化推导与迭代优化三部分组成：前者提供可追溯的信息输入，中间环节输出可执行的结构化策略，后者通过评审反馈提升可部署性与一致性。

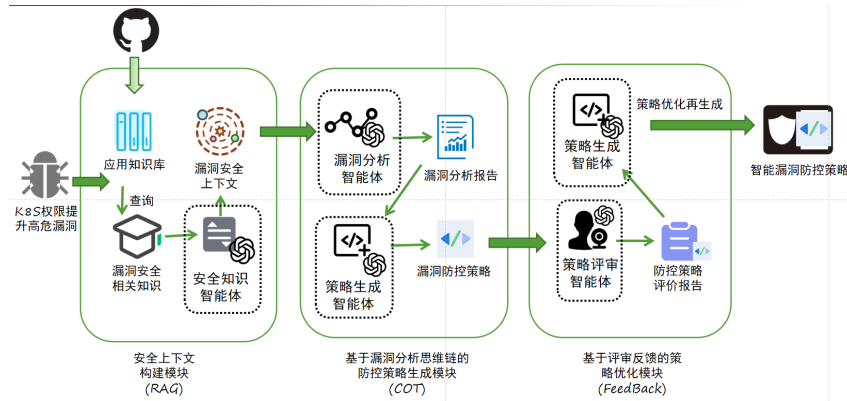


图 1-2: 框架流程示意，展示从上下文构建到策略生成与评价的主要步骤。

图1-2 给出了方法的流程示意，便于理解各阶段输入输出的衔接关系。

1.5.2 证据汇聚与上下文构建

该步骤从应用知识库与安全材料中检索并汇聚相关证据，重点遵循三项原则：其一，提高检索的准确性与覆盖度（例如采用分层检索与多策略召回）；其二，对每条证据显式记录来源标识，以支持后续复核；其三，对冗余与超长证据进行裁剪与去重，避免上下文过载影响后续分析。

1.5.3 结构化策略推导

该步骤将漏洞分析结果映射为可执行的防控策略，并将关键中间结论显式化。推导采用“流程约束 + 格式约束”的组合：流程约束将过程拆分为若干顺序阶段（漏洞分析、防控层次选择、防控方法设计、操作步骤规范化），前

一阶段输出作为后一阶段输入；格式约束对输出采用统一的结构化模式（例如 JSON schema），以提高字段完整性与可检查性。

根据定义 3，策略对象 π 由三个核心字段组成：防控层次（layer）、防控方法（method）与具体操作序列（actions）。具体的策略生成过程遵循如下结构化表达：

- **layer 字段**：防控所在的技术层面，用于分类防控策略所涉及的安全域，包括但不限于：
 - 身份与权限：RBAC、认证强化、ServiceAccount 管理等；
 - 网络隔离：防火墙规则、NetworkPolicy、流量隔离等；
 - 运行时检测：容器监控、系统调用检测、入侵检测等；
 - 审计与日志：日志记录、事件审计、合规监控等。
- **method 字段**：防控方法的摘要或分类，用于快速理解防控策略的整体思路，例如：
 - 网络隔离与认证强化；
 - 权限最小化与配置加固；
 - 检测与阻断相结合。
- **actions 字段**：具体可执行的操作序列，遵循定义 3.1，包含：
 - 对应的安全工具或修改对象（如 Cisco DNA Center、Kubernetes RBAC 配置）；
 - 具体的执行步骤，包括命令、参数、验证方式；
 - 副作用评估与回滚方案。

为提高交付可用性，本文对候选策略施加基本质量要求：操作序列应可在短时间内启动；至少覆盖一个明确的防控层次；包含可验证的执行步骤；对潜在副作用与回滚边界作出清晰说明。

候选策略集合 Π_o 的生成可采用多策略并行方法：对同一漏洞产生多个结构化策略对象，以探索不同的防控层次和防控方法。由于所有候选共享统一的 schema 结构（layer、method、actions），它们可直接进入后续的评价与排名流程。

在交付前，生成结果需进行规范化处理：统一各字段的格式、补齐缺失的操作步骤、清理冗余信息，并在数据缺失或不完整处显式标注假设条件和依赖的前置条件。

1.5.4 迭代优化与质检

该步骤通过独立评审和定向修订对候选策略进行质量控制。评审阶段对每个候选策略进行结构化检查，从有效性、干扰程度、可部署性等维度识别问题（可执行性缺陷、业务影响问题、证据支撑不足）；优化阶段基于评审结论对策略对象进行定向修订补齐缺失信息、将描述转化为可执行的动作清单、明确适用范围和约束条件。这一反馈闭环的设计使得生成阶段的随机性被限制在候选探索阶段，交付质量由结构化评价与可验证的改进清单支撑。

1.6 质量评价与筛选

该阶段对候选策略集合进行结构化评价，输出门槛评分 $s(\pi)$ 、多维质量向量 $q(\pi)$ 和策略排名 $R(\Pi_v, \text{dim})$ ，遵循“结构化输入 → 规则化检查 → 证据支撑的结论”的流程，以提高结论的可验证性。

1.6.1 门槛评分与质量评估

评分函数 $s : \Pi \rightarrow [0, 1]$ 用于判定策略是否满足最低可用性要求。该评分关注可部署性和风险降低效果。典型评价流程包括：

评价指标。建立可核查的检查清单，包括：

- 完整性检查（关键字段是否齐全，信息缺失是否标注）
- 可部署性检查（是否给出具体步骤、验证方法和回滚边界）
- 一致性检查（策略与安全上下文的一致性，是否包含无依据的断言）
- 约束合规检查（是否符合临时防控的适用范围）

评分聚合。检查项结果通过加权和进行聚合：

$$s(\pi) = \text{clip} \left(\sum_{j=1}^m w_j \cdot r_j(\pi), 0, 1 \right)$$

其中 $r_j(\pi)$ 为第 j 项的评分， w_j 为权重。部分关键项可设置为硬约束，即任何关键项失败则整体评分低于阈值。

流程控制。设定阈值 τ ，当 $s(\pi) < \tau$ 时策略转入反馈优化流程重新修订，当 $s(\pi) \geq \tau$ 时进入后续排名和筛选。

质量向量。对通过门槛的策略，进一步用三维向量刻画其特性：

$$q(\pi) = (E(\pi), I(\pi), D(\pi))$$

其中：

- $E(\pi)$: 有效性, 即覆盖关键攻击路径和降低风险的程度
- $I(\pi)$: 干扰程度, 即对业务运营、误报风险和运维复杂度的影响
- $D(\pi)$: 可部署性, 即步骤清晰度、可操作性和验证回滚能力

每个维度通过可观测指标聚合为 $[0, 1]$ 分数, 同时记录评分理由与证据来源。

1.6.2 多维排名

排名算子 $R(\Pi_v, \text{dim})$ 在指定维度上对候选策略进行排序:

$$R(\Pi_v, \text{dim}) \rightarrow (\pi_{(1)}, \pi_{(2)}, \dots, \pi_{(k)})$$

排名过程包括:

1. **过滤**。移除评分低于阈值 τ 的候选, 使后续排名的策略均可部署。
2. **排序**。按指定维度 (有效性、干扰程度或可部署性) 的评分降序排列。
3. **并列处理**。当分数接近时, 引入次级准则 (如降低干扰程度作为次级准则)。
4. **结果说明**。输出排名序列及每个策略的三维评分、关键优缺点和支撑证据。

1.6.3 评价驱动的迭代控制

评价结论决定策略是否可交付或需要进一步优化。当最高分候选仍低于阈值或关键维度存在缺陷时, 评价报告转化为修订约束触发下一轮反馈优化; 当候选达标时, 按维度排名并输出支撑证据。

1.7 LLM 生成的可靠性控制

在以生成模型辅助策略构建的场景中, 输出质量主要受三类因素影响: 生成过程的随机性、输入证据的不完整性, 以及对约束条件理解不一致带来的偏差。为提高结果的可复核性与可维护性, 本文采用如下机制对输出进行“可检查化”约束:

1. **结构化产物与字段检查**: 将策略固定为 (layer、method、actions) 三字段对象; 对字段完整性、格式一致性与动作序列可执行性进行规则化检查。
2. **证据来源追踪**: 对关键判断与关键配置项保留来源标识 (文件路径、链

接或片段 ID 等), 使“结论—证据”可回溯。

3. **分阶段输出与差异记录:** 将推导过程拆分为可验证的中间输出, 并在迭代修订时记录修改原因与变化点, 便于定位问题来源。
4. **多维评价与门槛控制:** 通过门槛评分过滤明显不可部署的候选, 再以质量向量进行排序, 从而将主观判断转化为可比较的检查结果。

上述机制的目标并非“消除不确定性”, 而是将不确定性限定在可定位、可复核的范围内, 使策略选择与交付过程具有一致的检查依据。

1.8 评估与展示

框架评估以“策略结果可比对、评价依据可追溯”为目标, 主要包括三类内容: 其一, 在同一漏洞与相同上下文下生成多个候选策略, 用于对比不同防控层次与方法的取舍; 其二, 依据评分与排名机制给出候选的结构化评价结果, 并输出对应的理由与证据; 其三, 从可部署性角度核查关键步骤是否可落地、验证方式是否明确、回滚边界是否清晰。

展示维度基于三维质量向量 $q(\pi) = (E(\pi), I(\pi), D(\pi))$: 有效性指策略对威胁的覆盖程度, 干扰程度指对业务和运维的影响, 可部署性指策略的清晰度和可操作性。

摘 要

论文中文摘要字数约为 300~600 字，如遇特殊需要字数可以略多，限一页。

论文摘要是论文内容不加注释和评论的简短陈述，一般以第三人称语气写成。摘要的编写应遵循下列原则：

1) 摘要应具有独立性和自含性，即不阅读论文的全文，就能获得必要的信息。摘要是学位论文的缩影，是学位论文的主要内容、见解、结论简短明了的缩写。

2) 摘要应是一篇完整的短文，可以独立使用，可以引用。

3) 摘要的内容应包含与论文等量的主要信息，供读者确定有无必要阅读全文，也可供文摘汇编等二次文献采用。

4) 摘要一般应说明研究工作的目的意义、研究方法、研究结果、主要结论及意义、创造性成果和新见解，而重点是结论和创新点。

5) 要用文字表达，不要附图和照片，除了实在无变通办法可用以外，摘要中不用图、表、化学结构式、非公知公用的符号和术语，不要使用表格、公式、上下标以及其他特殊符号，要突出重点，阐述清楚，少用数据表。论文摘要用语力求简洁、准确。原则上 300~600 字。

关键词：摘要；论文；要求；字数；格式（关键词个数为 3~5 个，正式写作请删除此括号）

Research on Dynamic Prevention and Control Technologies for Privilege Escalation Vulnerabilities in Cloud-Native Applications

ABSTRACT

In environmental economics, environmental resources including environmental quality are categorized as amenity resources. Due to its importance to human welfare, the amenity resources theoretical study and valuation is an ongoing issue at the academic frontier in the environmental economics area.

注：论文的英文摘要应有英文题目和关键词，内容与中文摘要相同，用另页置于中文摘要之后；外文摘要实词在 300 个左右。

Key Words: Key word 1; Key word 2; Key word 3; ...

序 (可选)

序并非必要。论文的序，一般是作者或他人对本篇基本特征的简介，如说明研究工作缘起、背景、主旨、目的、意义、编写体例，以及资助、支持、协作经过等；也可以评述和对相关问题研究阐述。这些内容也可以在主体部分引言中说明。

目 录

1 面向云原生应用权限提升漏洞的自动化防控技术报告	7
1.1 背景与问题	7
1.1.1 权限提升漏洞的分类	7
1.1.2 动机与挑战	9
1.2 形式化定义	10
1.2.1 基本对象	10
1.2.2 评价与选择	11
1.3 总体框架	12
1.4 知识库构建	12
1.5 策略生成	13
1.5.1 方法概览	13
1.5.2 证据汇聚与上下文构建	13
1.5.3 结构化策略推导	13
1.5.4 迭代优化与质检	15
1.6 质量评价与筛选	15
1.6.1 门槛评分与质量评估	15
1.6.2 多维排名	16
1.6.3 评价驱动的迭代控制	16
1.7 LLM 生成的可靠性控制	16
1.8 评估与展示	17
摘要	I
ABSTRACT	III
序 (可选)	V
插图和附表清单 (如有)	IX
符号清单 (如有)	XI
2 引言 (绪论)	1
2.1 研究背景	1
2.2 研究意义	1
3 文献综述	3
3.1 国内外研究现状	3
3.2 文献综述述评	3

4 研究设计	5
4.1 研究对象与方法	5
4.1.1 研究对象	5
4.1.2 研究方法	5
4.2 研究重点、难点和创新点	5
4.2.1 研究重点	5
4.2.2 研究难点	5
4.2.3 研究创新点	5
5 研究结果	7
6 研究分析与讨论	11
6.1（根据实际情况填写）	11
6.2（根据实际情况填写）	11
6.3（根据实际情况填写）	11
7 结论与展望	13
7.1 结论（根据实际情况填写）	13
7.2 展望（根据实际情况填写）	13
附录 A 单位	17
致谢	19
作者简历及在学研究成果	21
独创性说明	23
关于论文使用授权的说明	25
学位论文数据集	27

插图和附表清单（如有）

插图或附表清单并非必要。论文中如图表较多，可以有此页。图的清单应有图号、图题和页码。表的清单应有表号、表题和页码。

根据所列内容，可将本页标题分别更改为“插图清单”、“附表清单”。

符号清单（如有）

此页并非必要。符号、标志、缩略词、首字母缩写、计量单位、名词、术语等的注释说明汇集表，如需汇集，可集中置于此页。

根据所列内容，将本页标题分别更改为“符号清单”、“标志清单”、“缩写清单”、“计量单位清单”、“术语表”等。

2 引言（绪论）

2.1 研究背景

本部分主要介绍选题的研究背景，根据实际情况自行填写。

自行确定是否使用三级或四级标题。宋体小四号，两端对齐，首行缩进 2 字符，段前 0.1 行，段后 0.1 行，1.3 倍行距（段落中有数学表达式时，可根据需要设置该段的行距）。引文内容可用楷体。论文中出现英文时需要使用 Times New Roman 字体。这个结构可以根据自己论文需要进行调整。这些文字都是编的，根据需要自己撰写。

环境中黑炭 (black carbon) 气溶胶的主要来源包括各种化石燃料和生物质燃料的不完全燃烧过程，这些不完全燃烧在自然界和人类活动中都会发生，因此，环境中黑炭气溶胶的来源十分广泛 [1]。对当今大气环境中的黑炭，其主要来源是人类相关的燃料燃烧活动，此外，一些自然过程也会产生黑炭，如森林火灾、草原火灾等 [2, 3]。据过去的排放清单研究，大气环境中黑炭气溶胶的来源主要包括：1) 有机燃料的燃烧，主要包括能源行业、工业部门、交通运输行业、居民生活中煤、石油、天然气和各种生物质燃料的使用。通常而言，燃烧效率越高，产生的黑炭气溶胶的量越低；2) 工业炼焦，主要包括炼焦过程中的炼制过程、焦炉加热系统以及焦炉煤气的泄漏等等；3) 工业制砖，主要包括制砖过程中物料破碎输送、坯体人工干燥和烧成工段等过程；4) 垃圾焚烧，包括生活垃圾和工业废料的燃烧过程；5) 天然火灾和野外农业废弃物燃烧，包括森林、草原火灾和秸秆的燃烧。目前大部分研究表明，民用取暖和做饭过程中的燃料燃烧和城市柴油车是黑炭气溶胶大气排放量最大的源 [4-7]。这些文字都是编的，根据需要自己撰写。¹

2.2 研究意义

本部分主要介绍选题的研究意义，根据实际情况自行填写。

自行确定是否使用三级或四级标题。宋体小四号，两端对齐，首行缩进 2 字符，段前 0.1 行，段后 0.1 行，1.3 倍行距（段落中有数学表达式时，可根据需要设置该段的行距）。引文内容可用楷体。论文中出现英文时需要使用

¹论文正文中的脚注，宋体小五号，英：Time New Roman，两端对齐，单倍行距。

Times New Roman 字体。这个结构可以根据自己论文需要进行调整。

3 文献综述

3.1 国内外研究现状

本部分主要撰写国内外的研究现状，不能是文献资料的简单摘录，计算在重复率内，需要分类、总结、归纳。

自行确定是否使用三级或四级标题。论文中出现英文时需要使用 Times New Roman 字体。这个结构可以根据自己论文需要进行调整。

3.2 文献综述述评

本部分是对上述 2.1 的小结，重点说明以往研究对本研究的基础贡献、影响等。

自行确定是否使用三级或四级标题。论文中出现英文时需要使用 Times New Roman 字体。这个结构可以根据自己论文需要进行调整。

4 研究设计

4.1 研究对象与方法

4.1.1 研究对象

本部分主要介绍研究对象，根据实际情况填写。

自行确定是否使用四级标题。论文中出现英文时需要使用 Times New Roman 字体。这个结构可以根据自己论文需要进行调整。

4.1.2 研究方法

本部分主要介绍研究方法，根据实际情况填写。

自行确定是否使用四级标题。论文中出现英文时需要使用 Times New Roman 字体。这个结构可以根据自己论文需要进行调整。

4.2 研究重点、难点和创新点

4.2.1 研究重点

本部分主要介绍研究的重点，根据实际情况填写。

自行确定是否使用四级标题。论文中出现英文时需要使用 Times New Roman 字体。这个结构可以根据自己论文需要进行调整。

4.2.2 研究难点

本部分主要介绍研究的难点，根据实际情况填写。

自行确定是否使用四级标题。论文中出现英文时需要使用 Times New Roman 字体。这个结构可以根据自己论文需要进行调整。

4.2.3 研究创新点

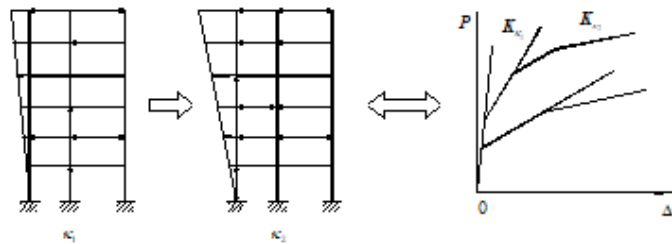
本部分主要介绍研究的创新点，根据实际情况填写。

自行确定是否使用四级标题。论文中出现英文时需要使用 Times New Roman 字体。这个结构可以根据自己论文需要进行调整。

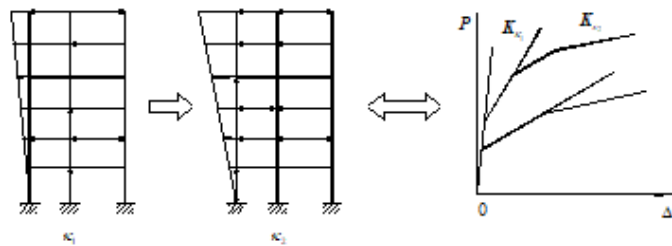
5 研究结果

自行确定是否使用四级标题。论文中出现英文时需要使用 Times New Roman 字体。这个结构可以根据自己论文需要进行调整。

如图 5-1，是这里插图的样式示例，以下不再重复，根据论文实际情况添加即可。



(a) 示意图 1



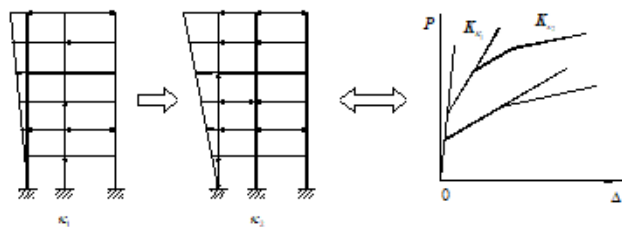
(b) 示意图 2

图 5-1: 非线性构形状态转移过程示意图

Fig. 5-1: Schematic diagram of nonlinear configuration state transition process.

(资料来源: XXXXXXXXXXXXXXXXXXXXXXXX)

续图示例:

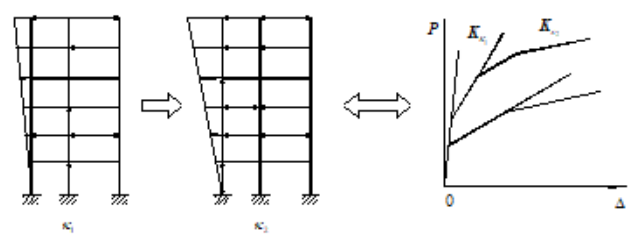


(a) 示意图 1

图 5-2: 数据图

Fig. 5-2: Data Graph

如表 5-1，是这里表格的样式示例，以下不再重复，根据论文实际情况添加即可。



(a) 示意图 2

图 5-2: 续
Fig. 5-2: Cont

表 5-1: 线性五杆结构各自由度随机反应数值特征

Tab. 5-1: Numerical characteristics of random response of linear five-bar structure with various degrees of freedom

x_1/m	F_x			x_2		
	均值/N	标准差/N	变异系数	均值/m	标准差/m	变异系数
0.000000	0.000000	0.000000	0.000000	0.000000	0.000000	0.000000
0.000100	206.006806	150.245905	0.729325	0.000024	0.000013	0.541667
0.000200	412.013613	215.100090	0.522070	0.000049	0.000018	0.367347
0.000300	618.020419	266.613296	0.431399	0.000073	0.000022	0.301370

续表示例:

表 5-2: 国际单位制中具有专门名称的导出单位

Tab. 5-2: Export units of special name in International System of Units

量的名称	单位名称	单位符号	其他表示示例
频率	赫 [兹]	Hz	s^{-1}
力; 重力	牛 [顿]	N	$\text{kg} \cdot \text{m}/\text{s}^2$
压力, 压强; 应力	帕 [斯卡]	Pa	N/m^2
能量; 功; 热	焦 [耳]	J	$\text{N} \cdot \text{m}$
功率; 辐射通量	瓦 [特]	W	J/s
电荷量	库 [仑]	C	$\text{A} \cdot \text{s}$
电位; 电压; 电动势	伏 [特]	V	W/A
电容	法 [拉]	F	C/V
电阻	欧 [姆]	Ω	V/A

这里公式的样式示例，以下不再重复，根据论文实际情况添加即可。

将剩余的试样分成两份后放入烘箱中，分别测量放入前和烘完后的质量，并对土体的含水率进行计算，密度取两份的平均值，计算公式为：

$$w = \frac{m_{water}}{m_2} = \frac{m_1 - m_2}{m_2} \times 100\% \tag{5-1}$$

式中： w 为含水率； m_1 为放之前的质量； m_2 为烘完之后的质量； m_{water} 为

表 5-2: 续
Tab. 5-2: Cont

量的名称	单位名称	单位符号	其他表示示例
电导	西 [门子]	S	A/V
磁通量	韦 [伯]	Wb	V • s
磁通量密度, 磁感应强度	特 [斯拉]	T	Wb/m ²
电感	亨 [利]	H	Wb/A
摄氏温度	摄氏度	°C	
光通量	流明	lm	cd • sr
光照度	勒 [克斯]	lx	lm/m ²
放射性活度	贝可 [勒尔]	Bq	s ⁻¹
吸收剂量	戈 [瑞]	Gy	J/kg
剂量当量	希 [沃特]	Sv	J/kg

试样的含水量。

说明 1: 根据实际情况占用 1 行或多行, 编号右端对齐, 表达式与编号之间可用“...”连接, 如有两个以上的表达式, 应用从“1”开始的阿拉伯数字进行编号, 并将编号置于圆括号内; 表达式较多时, 可分章编号, 如 (5-1) 表示第四章第一个表达式。

6 研究分析与讨论

6.1（根据实际情况填写）

根据研究结果，自行确定使用二级、三级标题内容。研究分析与讨论应是论文的精华，解释现象、阐述观点，说明研究结果的含义，应是研究后的水到渠成，不能是长篇大段的重复描述研究结果。

自行确定是否使用四级标题。论文中出现英文时需要使用 Times New Roman 字体。这个结构可以根据自己论文需要进行调整。

6.2（根据实际情况填写）

6.3（根据实际情况填写）

7 结论与展望

7.1 结论（根据实际情况填写）

研究结论应是简明扼要的陈述，是论文的精华，应是研究后的水到渠成，不能是长篇大段的描述。

自行确定是否使用三级标题。论文中出现英文时需要使用 Times New Roman 字体。这个结构可以根据自己论文需要进行调整。

……（根据实际情况填写）

根据论文实际情况撰写。一般情况下，论文的结论 2~4 条即可，不宜过多，根据本人论文的实际情况填写。

7.2 展望（根据实际情况填写）

展望是本项研究的局限性或研究中尚难解决的问题，并提出今后进一步在本研究方向进行研究工作的设想或建议。

自行确定是否使用四级标题。论文中出现英文时需要使用 Times New Roman 字体。这个结构可以根据自己论文需要进行调整。

……（根据实际情况填写）

参考文献

- [1] 美国妇产科医师学会 1111. 新生儿脑病和脑性瘫痪发病机制与病理生理. 人民卫生出版社, 北京, 2010. 段涛, 杨慧霞, 译, 38–39 页.
- [2] 汪昂. 增订本草备要: 四卷. 老二酉堂, 京都, 1881. 刻本, 清光绪七年.
- [3] 蒋有绪, 郭泉水, 马娟, and 等. 中国森林群落分类及其群落学特征. 科学出版社, 北京, 1998.
- [4] 侯文顺. 高分子物理: 高分子材料分析、选择与改性. 化学工业出版社, 北京, 2010. URL <http://apabi.lib.pku.edu.cn/usp/pku/pub.mvc?pid=book.detail&metaid=m.20111114-HGS-889-0228>. 119 页, 2012-11-27 在线访问.
- [5] W. Crawford and M. Gorman. *Future Libraries: Dreams, Madness, & Reality*. American Library Association, Chicago, 1995.
- [6] International Federation of Library Associations and Institutions. *Names of Persons: National Usages for Entry in Catalogues*. IFLA International Office for UBC, London, 3 edition, 1977.
- [7] J. A. O'Brien. *Introduction to Information Systems*. Irwin, Burr Ridge, Ill, 7 edition, 1994.

附录 A 单位

以下内容可放在附录之内：

- (1) 正文内过于冗长的公式推导；
- (2) 方便他人阅读所需的辅助性数学工具或表格；
- (3) 重复性数据和图表；
- (4) 论文使用的主要符号的意义和单位；
- (5) 程序说明和程序全文；
- (6) 企业应用证明；
- (7) 项目鉴定报告；
- (8) 获奖成果证书；
- (9) 设计图纸；
- (10) 程序源代码；
- (11) 论文发表；
- (12) 作者简介。

这部分内容可省略。如果省略，删掉此页。

书写格式说明：

标题“附录 A 附录内容名称”样式为字体：黑体，英文用 Times New Roman 字体，居中，加粗，字号：小三，2.41 倍行距，段前 17 磅，段后为 16.5 磅。

附录正文样式为字体宋体小四，英文用 Times New Roman 字体小四，两端对齐书写，段落首行左缩进 2 个字符。1.3 倍行距（段落中有数学表达式时，可根据表达需要设置该段的行距），段前 0.1 行，段后 0.1 行，1.3 倍行距。

示例

表 A-1: 表 A.1 国际单位制的基本单位

量的名称	单位名称	单位符号
长度	米	m
质量	千克 (公斤)	kg
时间	秒	s
电流	安 (培)	A
热力学温度	开 (尔文)	K
发光强度	坎 (德拉)	cd

表 A-2: 表 A.2 国家规定的非国际单位制单位

量的名称	单位名称	单位符号	换算关系和说明
时间	分	min	1 min=60 s
	[小] 时	h	1 h=60 min=3600 s
	天 (日)	d	1 d=24 h=86400 s
平面角	[角] 秒	"	$1'' = (\pi/648000) \text{ rad}$
	[角] 分	'	$1' = 1^\circ/60 = (\pi/10800) \text{ rad}$
	度	°	$1^\circ = (\pi/180) \text{ rad}$
	度	°	$1^\circ = (\pi/180) \text{ rad}$
旋转速度	转每分	r/min	1 r/min=(1/60) r/s
长度	海里	n mile	1 n mile=1852 m
速度	节	kn	1 kn=1 n mile/h=(1852/3600) m/s (只用于航行)

致 谢

致谢是作者对该论文的形成作出过贡献的组织或个人予以声明的文字记载，语言要客观、准确、简短。

字数一般不超过 500 字，最多不超过一页。论文作者可以在致谢页对下列方面致谢：

国家科学基金、资助研究工作的奖学金基金，合同单位、资助或支持的企业、组织或个人；

协助完成研究工作和提供便利条件的组织或个人；

在研究工作中提出建议和提供帮助的人；

给予转载和引用权的资料、图片、文献、研究思想和设想的所有者；

其它应感谢的组织或个人。

作者简历及在学研究成果

一、主要教育经历/工作经历（从大学起，到博士入学止）

起止年月	学习或工作单位	备注
XXX 年 XX 月至 XXXX 年 XX 月	在 XXXX 学校 XXXX 专业攻读学士学位	
XXX 年 XX 月至 XXXX 年 XX 月	在 XXXX 单位从事 XXXX 岗位的工作	
XXX 年 XX 月至 XXXX 年 XX 月	在 XXXX 学校 XXXX 专业攻读博士学位	

二、在学期间从事的科研工作

（1）高性能低功耗深度神经网络处理器芯片设计（USTB06500093），主要参与人员，2017.11-2022.11。

（2）...

三、在学期间所获的科研奖励

（1）博士研究生国家奖学金

四、在学期间发表的论文

- [1] **Liu M K**, LIU C X, ZHANG S T, et al. Research on Industry Development Path Planning of Resource-Rich Regions in China from the Perspective of “Resources, Assets, Capital” [J]. Sustainability, 2021, 13(7): 3988-3988.
- [2] **Liu M K**, LIU C X, PEI X D, et al. Sustainable Risk Assessment of Resource Industry at Provincial Level in China [J]. Sustainability, 2021, 13(8): 4191-4191.
- [3] **刘明凯**, 张寿庭, 刘昌新, 等. 基于“三资”视角的矿山企业绿色可持续发展路径研究 [J]. 中国矿业, 2020, 29(07): 35-43.

- [4] **刘明凯**, 张红艳, 王新宇. 广西有色金属产业链关联测度与发展路径规划研究 [J]. 中国国土资源经济, 2020, 33(12): 65-74.
- [5] 虎海峰, **刘明凯**, 樊杰. 黄河流域经济-社会-生态耦合协调效应评价及预测 [J]. 中国管理科学. 待刊出.

盲审说明（正式写作请删除此说明）：

盲审论文需要隐藏掉所有会影响盲审结果的论文作者及其导师的信息，以便论文评阅人能够公正的进行评阅。

当学校要求提供盲审论文时，请按如下方法制作。

1) 对于论文中下列学生和导师信息。请将学生姓名、学生学号、导师姓名，依次全部替换为[本论文作者]、[论文作者学号]、[本论文导师]。论文中上述信息均需要替换，包括作者研究成果等部分的有关信息。

2) 在研究成果中，论文作者发表的文章列表中应隐去所有作者的名字，只标明论文期刊名，级别，发表年份。

3) 盲审论文，请不要填写致谢，致谢页除标题、页眉、页码外请保持空白。

4) 其他会影响盲审结果的信息，请采用类似方式处理。

5) 提交的盲审论文应为正式论文，除了上述替换后的信息外，应为可以评阅的正式论文。

6) 论文封面，请填写专业名称、论文题目等，将学号和姓名项目保持空白不填。制作盲审论文时，论文书脊、封二、题名页请删除。

替换前后将文档分别保存，以便盲审论文与其他论文分开管理。

盲审样例（正式写作请删除此样例）：

五、在学期间发表的论文：

[1] **第一作者**. 中国矿业. 中文核心期刊.2020.

[2] **第二作者（导师一作）**. 中国矿业. 中文核心期刊.2020.

独创性声明

本人声明所呈交的论文是我个人在导师指导下进行的研究工作及取得的科研成果。尽我所知，除了文中特别加以标注和致谢的地方外，论文中不包含其他人已经发表或撰写过的研究成果，也不包含为获得北京科技大学或其它教育机构的学位或证书而使用过的材料。与我一同工作的同志对本研究所做的任何贡献均已在论文中作了明确的说明并表示了谢意。

作者签名：_____ 日期：_____ 年_____ 月_____ 日

备注：提交时须有作者亲笔签名！

关于论文使用授权的说明

本人完全了解北京科技大学有关保留、使用学位论文的规定，即：学校有权保留送交论文的复印件，允许论文被查阅和借阅；学校可以公布论文的全部或部分内容，可以采用影印、缩印或其他复制手段保存论文。

（保密的论文在解密后应遵循此规定）

签名：_____ 导师签名：_____ 日期：_____

学位论文数据集

关键词 *	密级 *	中图分类号 *	UDC	论文资助
学位授予单位名称 *		学位授予单位代 码 *	学位类别 *	学位级别 *
北京科技大学		10008		
论文题名 *		并列题名		论文语种 *
作者姓名 *			学号 *	
培养单位名称 *		培养单位代码 *	培养单位地址	邮编
北京科技大学		10008	北京市海淀区学 院路 30 号	100083
学科专业 *		研究方向 *	学制 *	学位授予年 *
论文提交日期 *				
导师姓名 *			职称 *	
评阅人	答辩委员会主席	答辩委员会成员		
	*			
电子版论文提交格式文本 () 图像 () 视频 () 音频 () 多媒体 () 其他 () 推荐格式: application/msword; application/pdf				
电子论文出版 (发布) 者		电子论文出版 (发布) 地		权限声明
论文总页数 *				
共 33 项, 其中带 * 为必填数据, 为 22 项。				